

sansan

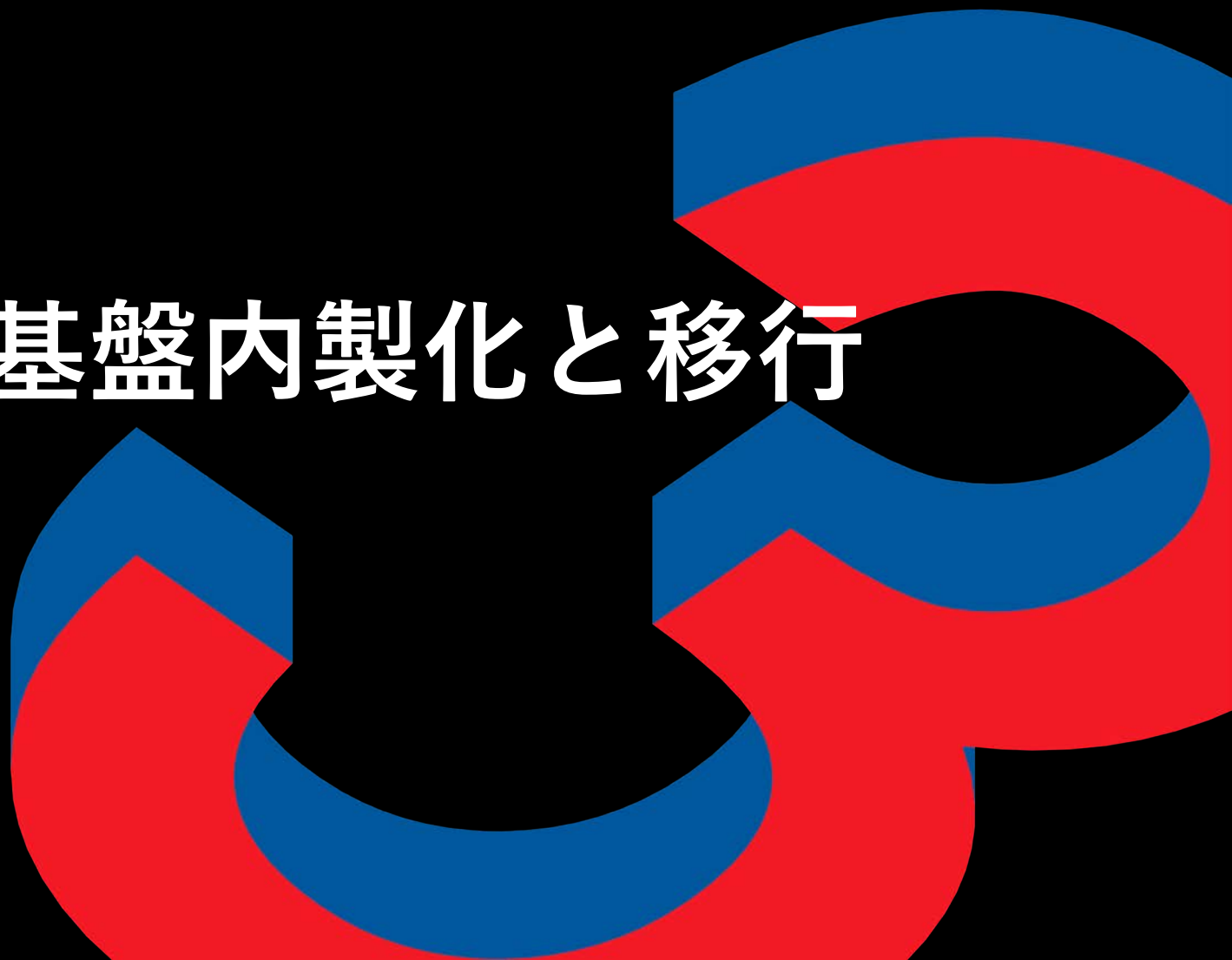
各社の事例に学ぶ！ 共通ID基盤 Lunch Talk

Sansanでの認証基盤内製化と移行

Sansan技術本部

Platform Engineering Unit

樋口 礼人





樋口 礼人 (Ayato Higuchi)

Sansan株式会社 技術本部

Platform Engineering Unit / Identity Platformグループ



Sansanのソフトウェアエンジニア

- 2022年5月 中途入社しContract Oneの開発を担当
- 2023年9月 Bill Oneへ異動し認証基盤の内製化に携わる
- 2025年6月 チームごとPlatform EUへ異動

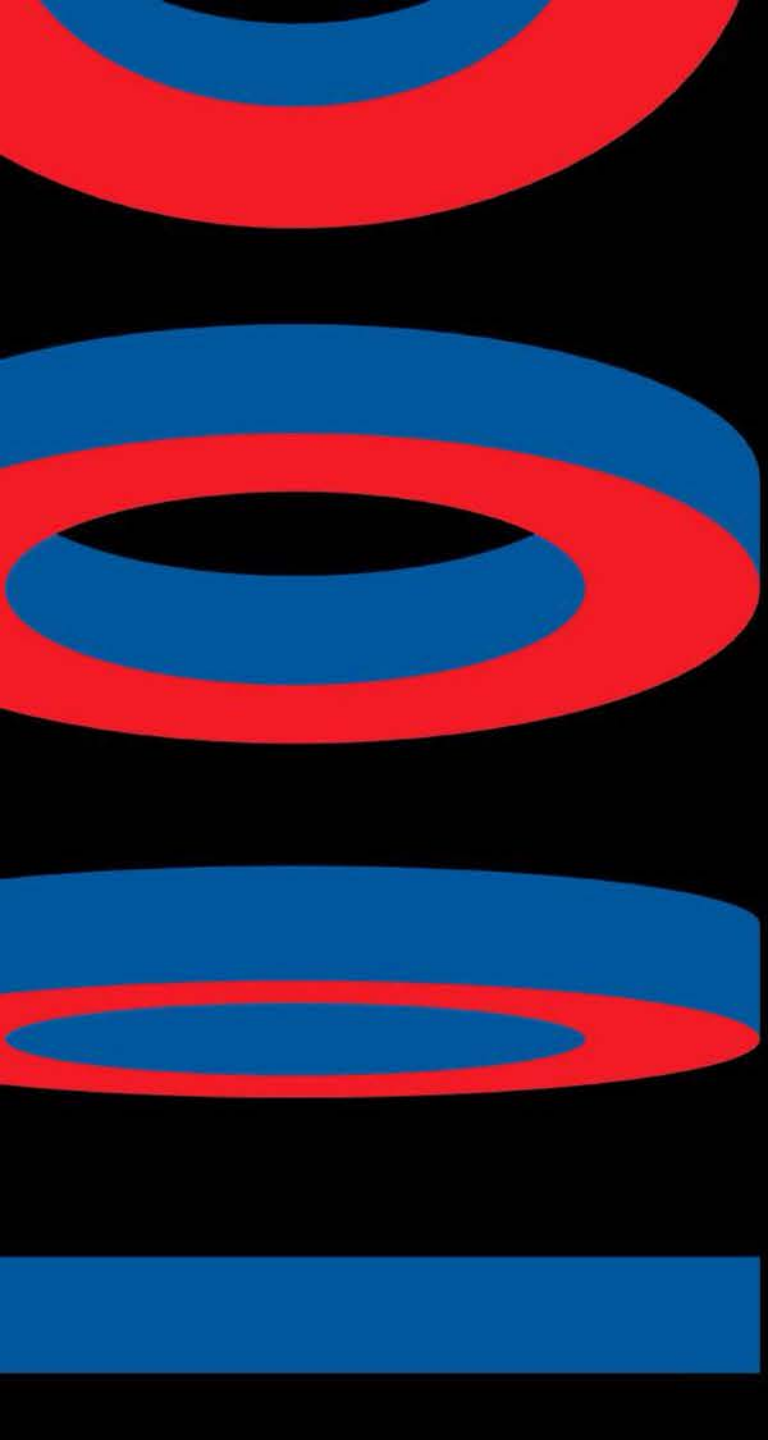
趣味：ポッドキャストを聞くこと

寄稿：Software Design 2025年12月号

「今さら聞けないID管理」 第4章

| Agenda

1. Sansan / Bill Oneにおける認証基盤の課題
2. 認証基盤の技術選定・設計と移行について
3. 認証基盤内製化の振り返り



Sansan / Bill Oneにおける 認証基盤の課題

Sansan株式会社の働き方を変えるAXサービス

生産性を向上させ、企業のAI活用を最大化するデータベースとしても貢献できる
「働き方を変えるAXサービス」を提供します。

法人向け

名刺管理から、収益を最大化する

sansan

ビジネスデータベース

営業

AI契約データベースが、利益を守る 「なくせる」をつくり、全社の働き方を変える

Contract One
powered by Sansan

取引管理サービス

契約

Bill One
powered by Sansan

経理AXサービス

請求

データクオリティマネジメント

**Sansan
Data
Intelligence**

個人向け

eight

名刺アプリ

名刺
管理

各サービスの活用で変わる働き方

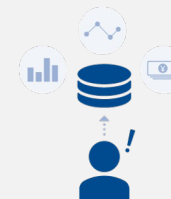
必要な情報を
すぐに見つけられる



情報の管理がしやすく
すぐに共有できる



情報を分析・活用しやすく
データに基づいた判断ができる



従来の認証基盤

経理AXサービス「Bill One」

- 2019年に開発スタート
- 2020年5月にリリース
- ファーストリリースまで3～5名の少数体制
 - 現在のチーム数は27
- 認証基盤としてAuth0を利用する方針
 - セキュリティ・可用性を担保
 - 開発リソースをプロダクト本体に集中

Auth0とは

Okta社が提供する

開発者向けのIDaaS (Identity as a Service)

- セキュリティ機能が充実
 - MFA (Multi Factor Authentication)
 - ブルートフォース攻撃対策など
- 簡単にOIDC・SAMLでのシングルサインオンに対応できる

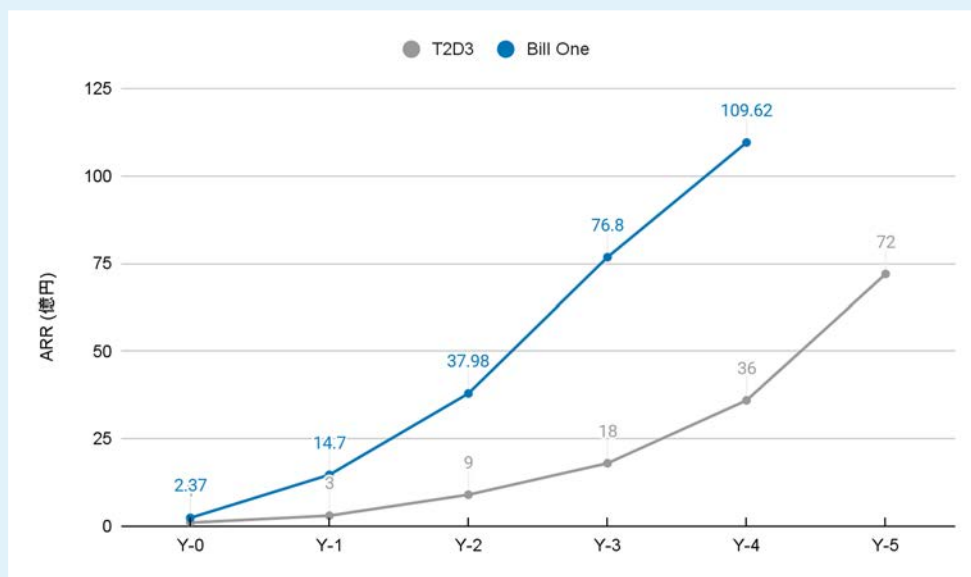
| プロダクト・会社の成長に伴い顕在化してきた課題

**Bill Oneでの
Auth0の
利用コスト**

**認証周りの
人材・ノウハウの
分散**

Bill OneでのAuth0の利用コスト

ARR リリースから5年で
T2D3を超える成長速度



- サービスが急速に成長
- 成長に伴いユーザー数も増加
- 1年でMAUは2倍以上に増加

2021年5月

2.37 億円



2025年5月

109.62 億円

認証周りの人材・ノウハウの分散

- 当社では歴史的にプロダクトごとの独立性が高い
 - ユーザー管理や認証も分かれている
- 全社横断での改善が進めづらい
- 新規プロダクトでの人材確保が難しい
 - IDaaSを使っても認証認可やSSO周りの知見は必要

				
主要言語	C#	Kotlin	Kotlin / Go	Ruby
インフラ	AWS	Google Cloud	Google Cloud	AWS
IDaaS	-	Auth0	Auth0	-

認証基盤内製化の経緯

Bill Oneでは認証基盤としてAuth0を利用していた

課題

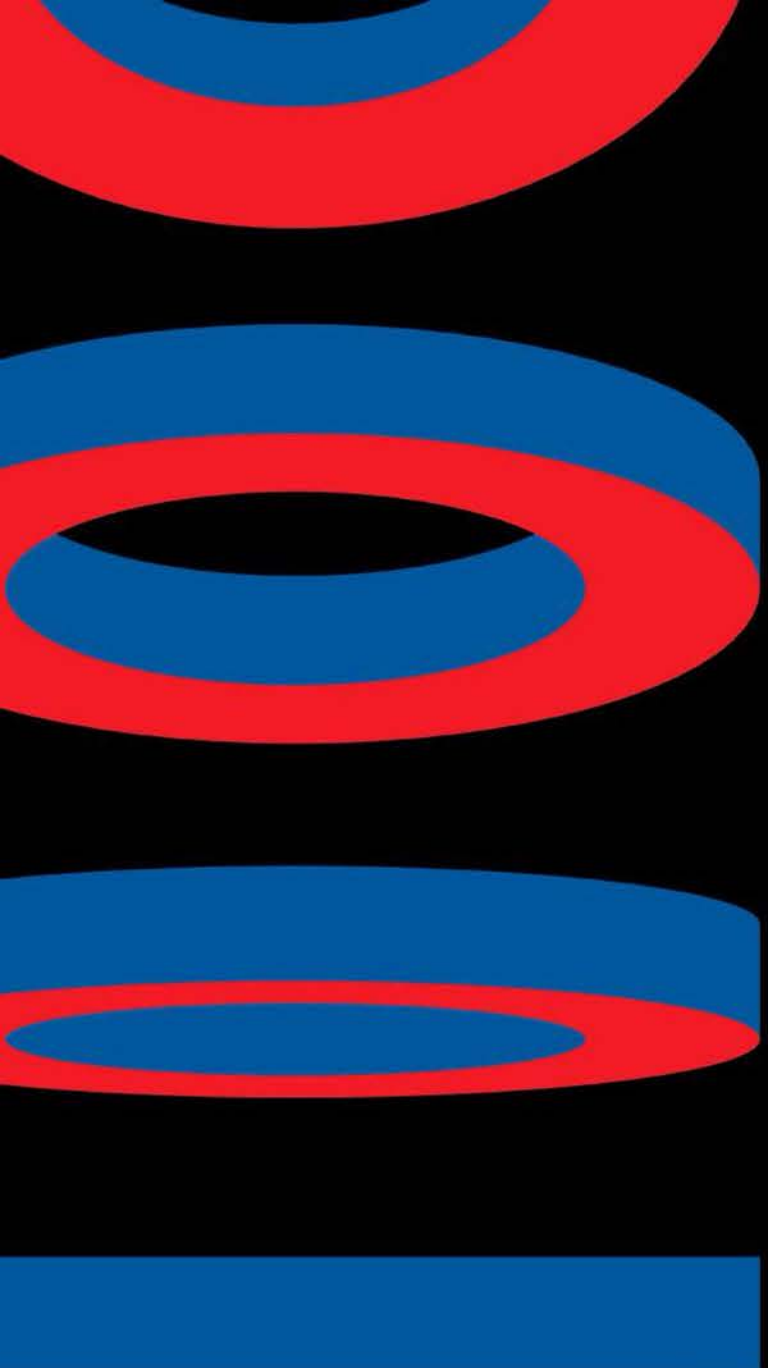
1. サービスの成長に伴うAuth0利用コストの増加
2. 歴史的経緯による認証周りのノウハウ・人材の分散



専門チームを組んで認証基盤を内製化し、プロダクトの共通認証基盤とする



3～4名のタスクフォースで内製化に取り組むことに



認証基盤の技術選定・設計 と移行について

認証基盤構築の選択肢

選択肢	メリット	デメリット
完全自前開発	完全な自由度	開発・運用コスト大
Keycloak等のOSS	開発工数低	運用負荷・セキュリティ
Auth0以外のIDaaSへ移行 + 自前開発	カスタマイズ性とセキュリティのバランス	一定の開発コスト
Auth0以外のIDaaSへ移行	運用負荷低、セキュリティ	カスタマイズ性低

代表的なIDaaSの料金

- Auth0のMAU単価は非常に高い
- IDaaS移行によって、大幅なコスト削減につながることがわかった

サービス	MAU単価 (月額)	備考
Auth0	\$0.24	B2B Professionalプランで7,500 MAUの場合の参考値 ※ 実際の契約額とは異なります https://auth0.com/pricing
Amazon Cognito	\$0.0055 ~ 0.0025	東京リージョン 50,000MAUまで無料 それ以降MAUに応じてディスカウント https://aws.amazon.com/cognito/pricing
Google Cloud Identity Platform	\$0.0055 ~ 0.0025	49,999MAUまで無料 それ以降MAUに応じてディスカウント
Azure AD B2C (Premium P1)	\$0.00325	50,000MAUまで無料 2025年5月1日以降Azure AD B2Cは新規の利用が停止

新しい認証基盤に必要な要件

- 既存のログイン体験を維持するためのログイン画面のカスタマイズ性
- 自社の基準を満たせるパスワードポリシーの設定機能
- TOTP (Time-based One-Time Password) によるMFA (Multi-Factor Authentication)
- ブルートフォース対策
 - 複数回ログイン失敗でのアカウントロック
 - 不審なIPアドレスのブロック

**Auth0では実現できていた内容だが、IDaaSを移行した場合、
自前開発せずに素直に実現することは難しい**



将来の拡張性も踏まえ、足りない機能は自前開発で補う

最終的な方向性

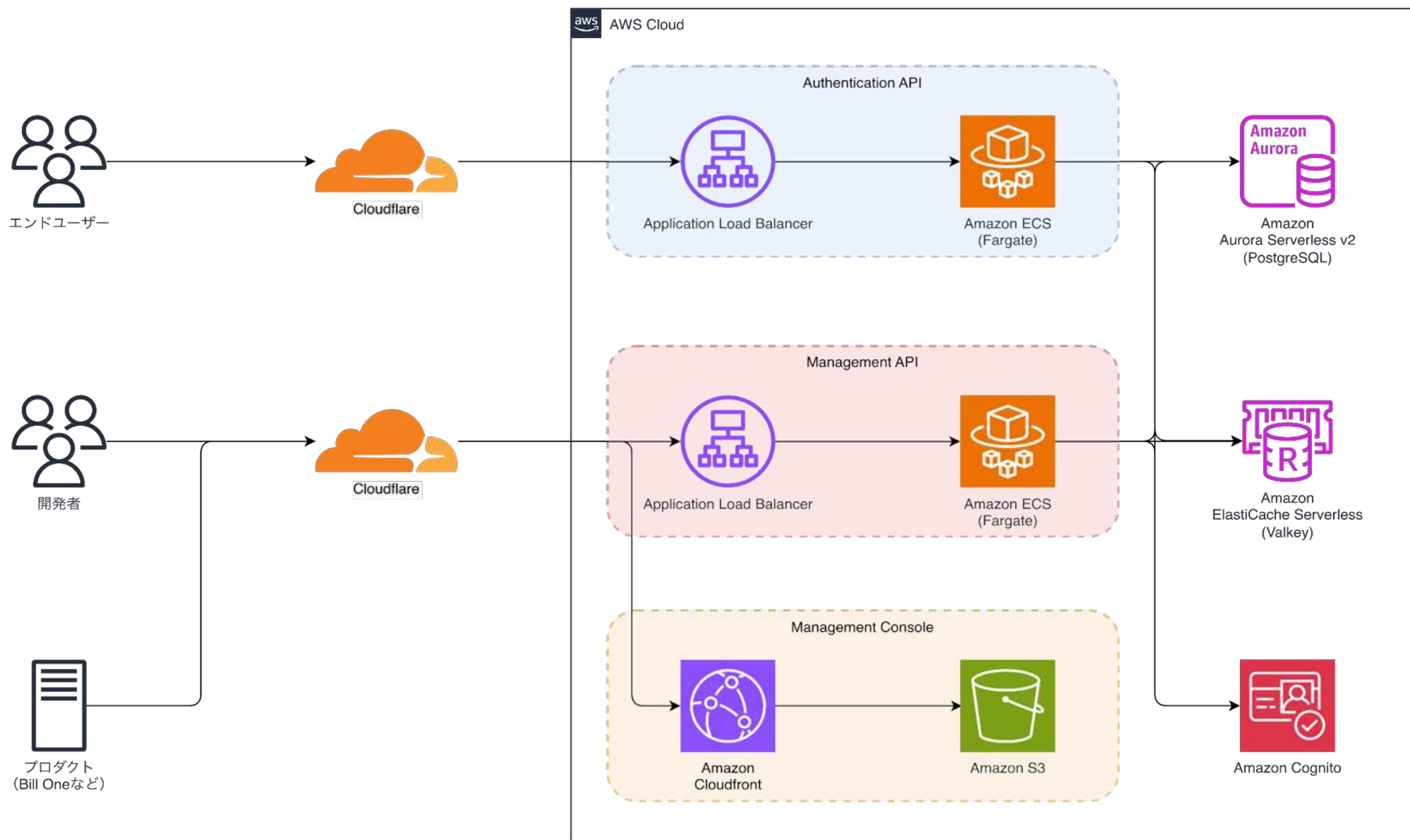
IDaaSの移行 + 自前開発

- IDaaS
 - Amazon Cognito
- クラウドサービス
 - アマゾン ウェブ サービス (AWS)
- OSSを利用し認可サーバーを自作
 - 認証部分はCognitoに任せる

Amazon Cognitoの選定理由

- コスト削減が見込める
- TOTPでのMFAに対応
 - 当時は対応していないIDaaSも
- API経由で認証機能が利用できることから
自前のアプリケーションで機能を
補いやすい
- 社内でAWSを得意とするメンバーは多い

システム構成



運用負荷を考慮し
サーバーレスを
積極的に採用

Backend

- Go
- Connect RPC

Frontend

- TypeScript
- React



認証基盤の移行について



アカウント移行の選択肢

✕ パスワードなどを再設定してもらう

- ユーザーの負荷が大きいため見送り

✕ パスワードハッシュなどをインポート

- Auth0は、パスワードハッシュを含むユーザー情報のエクスポートが可能だが、具体的な**実行日時の保証がない**
- Amazon Cognitoはパスワードハッシュの一括インポートを**サポートしていない**

✓ JIT(Just-In-Time)移行

- ダウンタイムなく、ログイン情報（パスワード）を引き継げる
- **Amazon CognitoのLambdaトリガーを利用して実現可能**

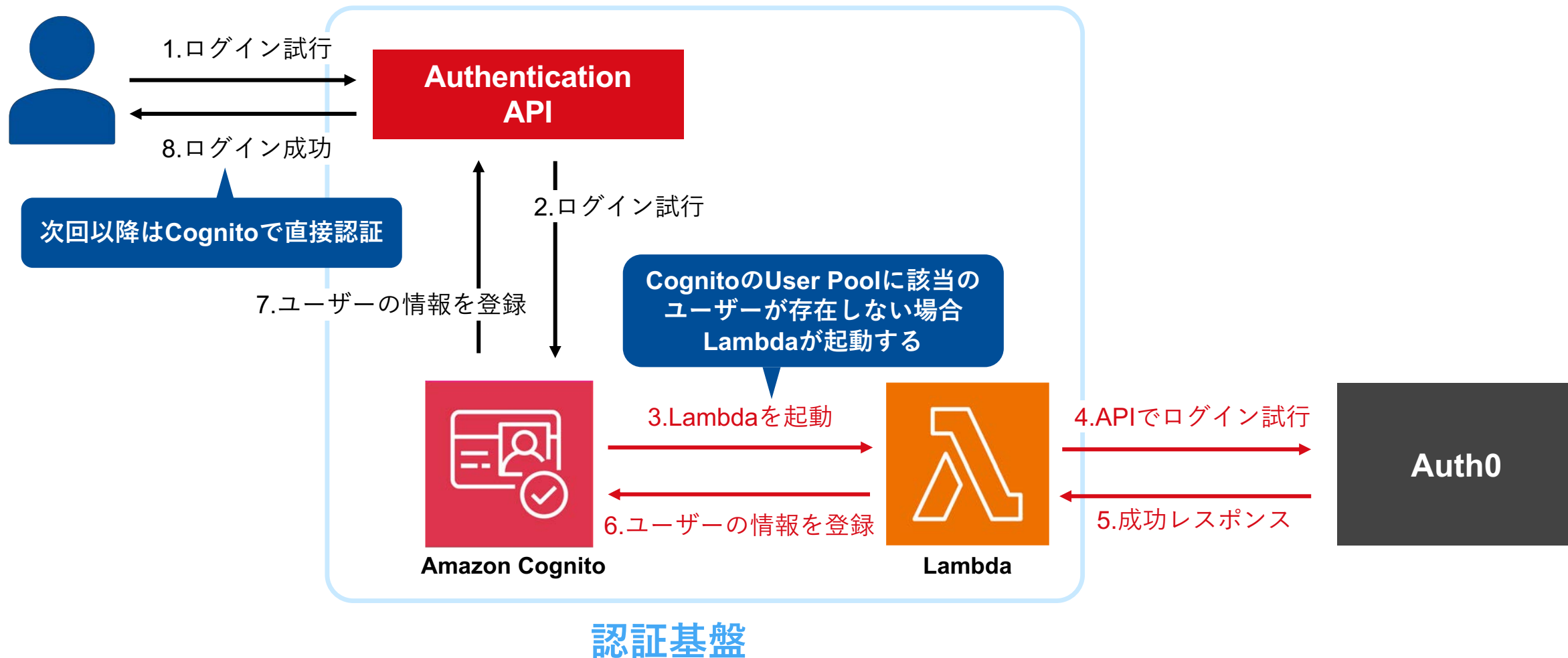
| Amazon CognitoのLambdaトリガーとは

認証・サインアップなどいくつかのタイミングで起動するLambda関数を設定しておくことで、デフォルトの動作を変更することができる

ユーザー移行のLambdaトリガー

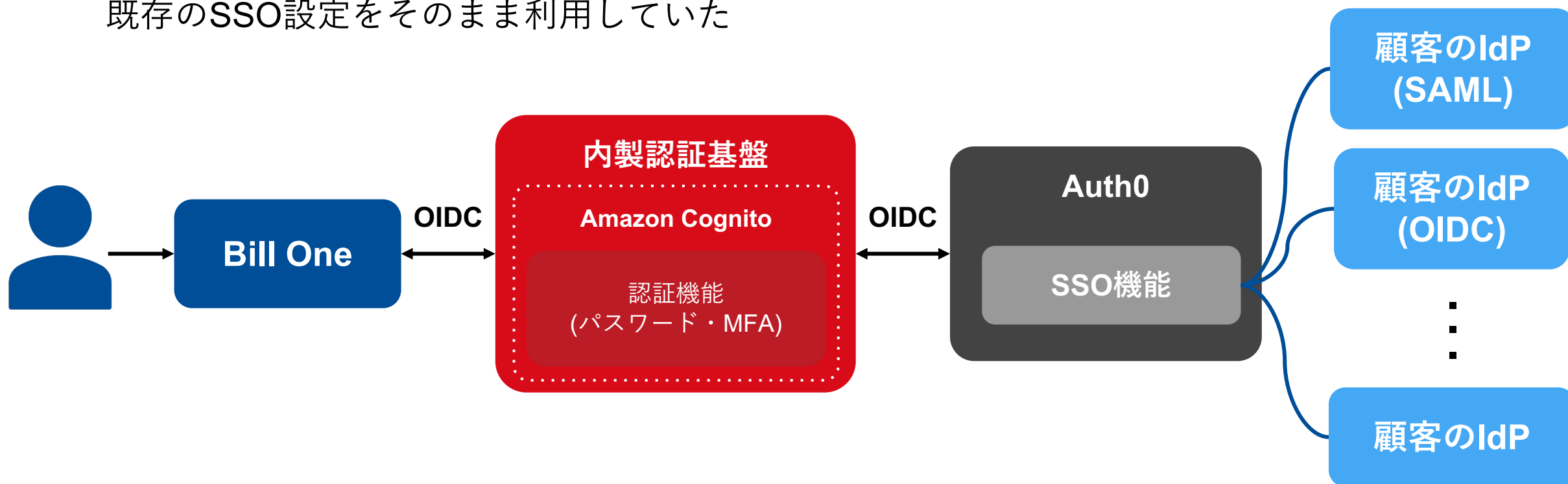
- ログインやパスワード再設定時に旧基盤から新基盤へアカウント情報を移行することができる
- ログイン・パスワード再設定時にCognitoのUser Poolにアカウントが存在しない場合、Lambdaから旧基盤へ問い合わせを行うことでアカウント情報を移行する

ログイン時のアカウント移行の流れ



シングルサインオンの移行

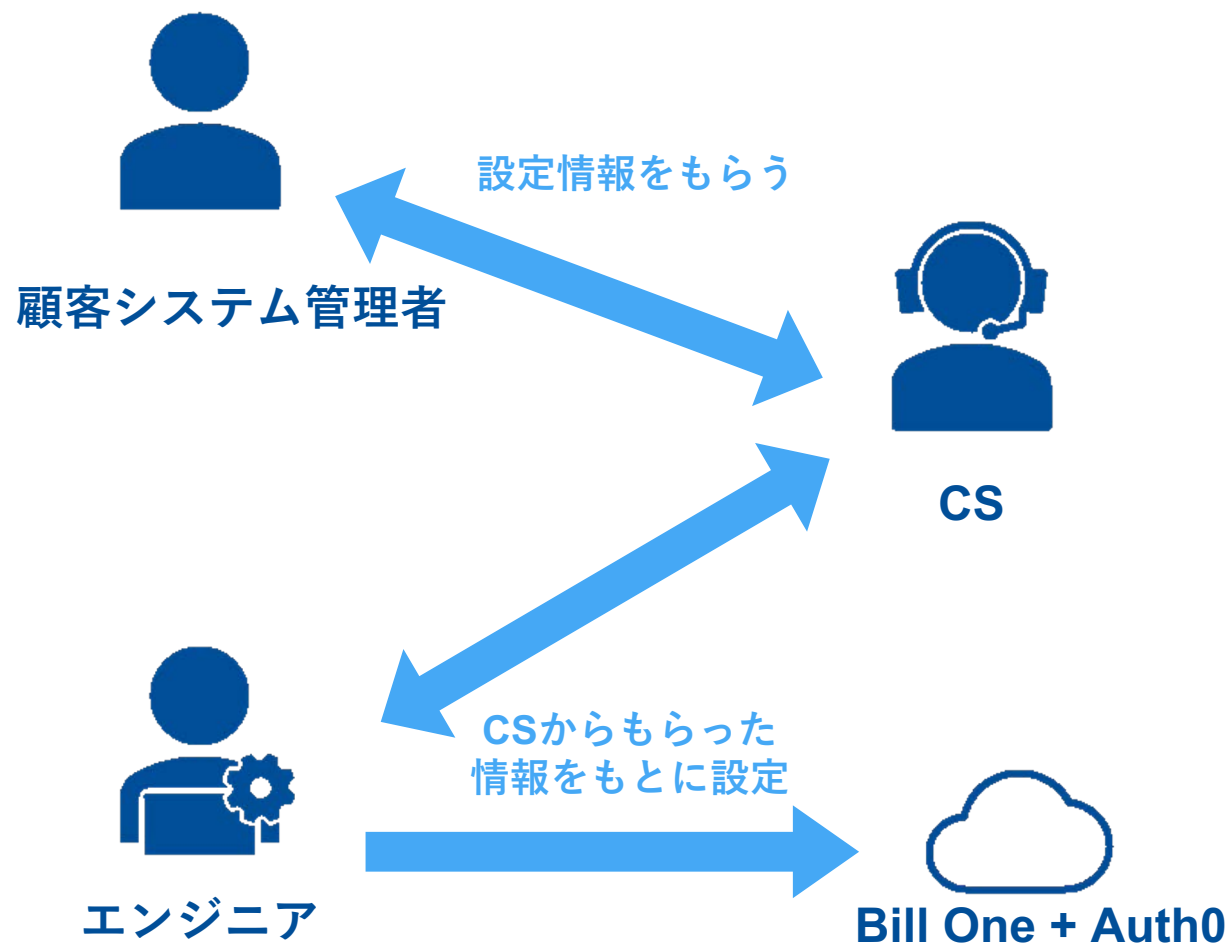
- 移行の初期段階ではSSOは引き続きAuth0を利用する方針としていた
- SSOを利用するユーザーの割合は小さく、契約更新のリミットを優先
- SSO利用ユーザーのログインの場合、新認証基盤からAuth0を経由してSSOさせることで、既存のSSO設定をそのまま利用していた



シングルサインオンの移行

移行における課題

- 移行には顧客IdP側の設定変更も必要
- これまでシングルサインオンの設定はエンジニアが**手作業**で実施していた
 - コミュニケーション・作業の工数が定常的に発生
 - 設定ミスが発生することも
- このまま数百のテナントの設定をやり直すには莫大な工数がかかるため非現実的



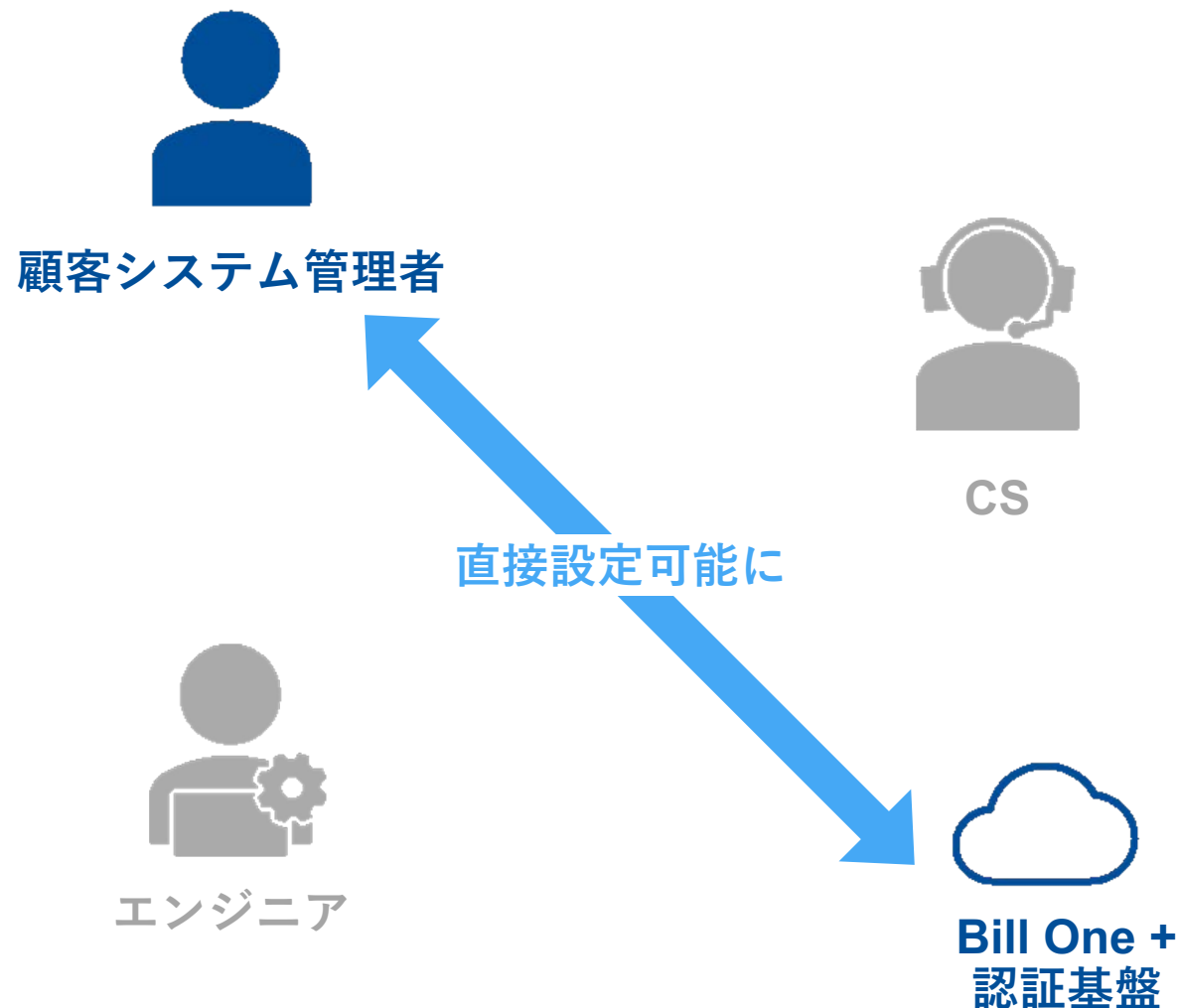
シングルサインオンの移行

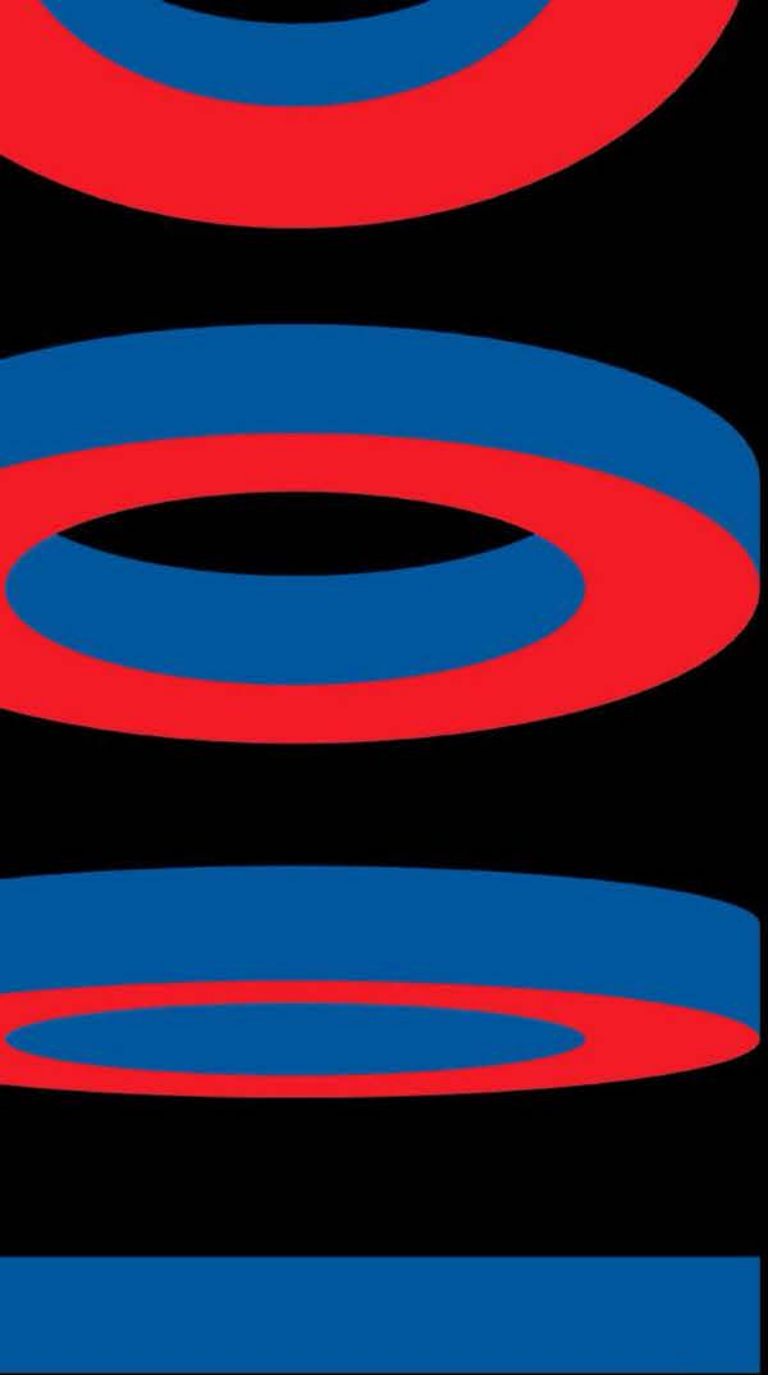
設定画面を実装し設定を セルフサービス化

- 既存テナントは画面上から再度設定してもらうことで新しい認証基盤を利用したSSOに切り替わる

結果

- 約3ヶ月で設定の移行を完了
- トイルを削減することで月当たり10～30時間の工数を削減





認証基盤内製化の振り返り

内製化の成果

大幅なコスト削減に成功

- IDaaSとOSSを活用して短期間での内製化を実現
- 認証基盤のコストを約90%削減

専門チームを設立

- 横断組織として独立、ノウハウの集約が可能な状態に

独自の機能拡張が可能になり体験の改善がスムーズに

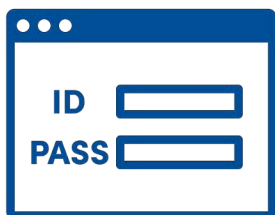
- Home Realm Discoveryの改善などを実施

■ 認証基盤切り替え時のドメイン変更による影響

ログイン画面のドメイン変更による、一時的な問い合わせの増加

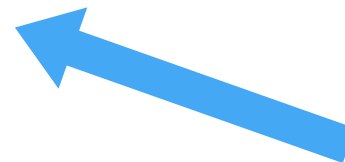
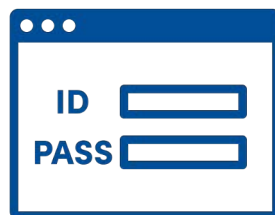
- 共通基盤化を考慮し、bill-one.com配下からsansan.com配下へ変更
- ドメイン変更によってパスワードマネージャーの補完が効かなかったり、Sansanのパスワードが補完されてしまうユーザーが発生

Bill Oneの旧ログイン画面
(auth.bill-one.com)

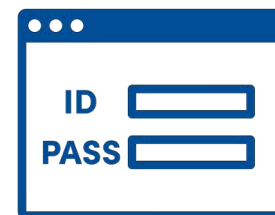


Bill Oneの
ID/パスワード

Bill Oneの新ログイン画面
(auth.sansan.com)



Sansanのログイン画面
(ap.sansan.com)



Sansanの
ID/パスワード

| IDaaS・OSSの限界

Amazon Cognito単体の機能ではカバーできないケース

- Amazon Cognitoにはリカバリコードを発行する機能がない
 - > Cognito採用にあたって妥協した機能だったが、MFAリセットの問い合わせが微増
 - > システム管理者がユーザーのMFAをリセットできるようにしたり、リカバリーコードを発行する機能を自前で開発することで対応

OIDCのライブラリの機能不足

- e.g. PKCE(Proof Key for Code Exchange)がPublic Clientでしか利用できない
 - Confidential Clientでも認可コードのインジェクションやCSRFの対策として有効
- 不足している機能の追加などはOSSコントリビュートで対応

sansan
